Foundations of Cybersecurity

Project Report

Bacciottini Leonardo
Paolini Emilio

ACADEMIC YEAR 2019/2020

Contents

1 Introduction **2**

2 Protocols **3**
2.1 FRAH Protocol 3
2.2 P2P Handshake Protocol 4

3 Ban Logic **7**
3.1 FRAH Protocol 7
3.2 P2P Handshake Protocol 10

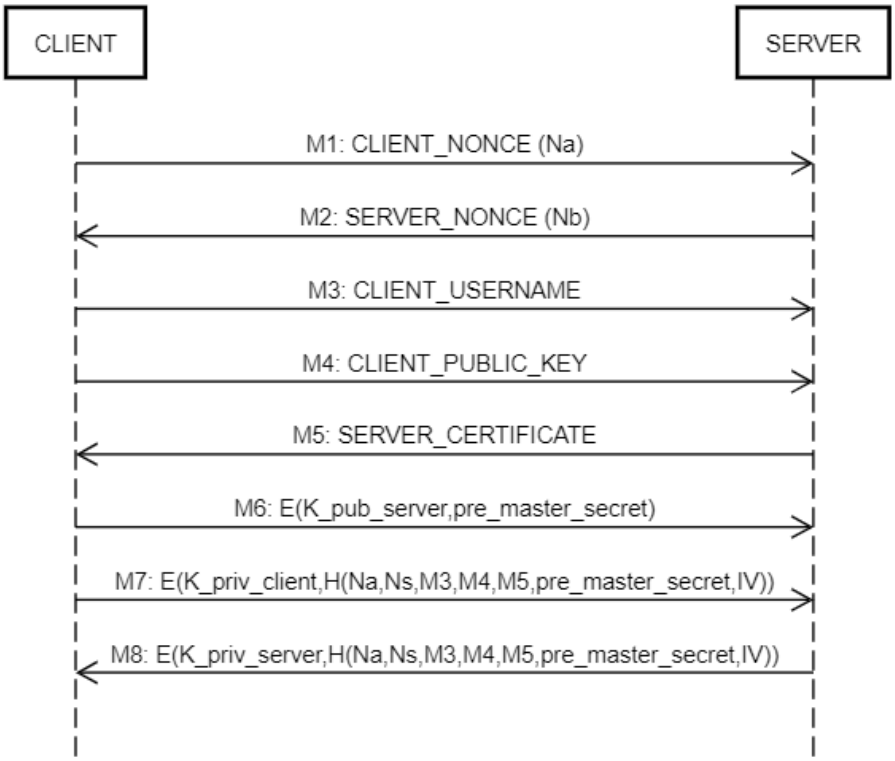
1 Introduction

The goal of the project is to implement a secure client-server four-in-a-row. In particular, when the client starts it asks the user if he/she wants to be a challenger or wants to wait for a challenge. If the user chooses the first option, then he/she can send a challenge to another user who chose the second option. Then, the client that receives a challenge can either accept or refuse it. If the user accepts the challenge, the game starts. The application also handles possible error situation, for example if a user challenges another challenger.

2 Protocols

2.1 FRAH Protocol

The FRAH protocol(Four-in-a-Row Authentication Handshake) is the protocol used by the client and the server to authenticate. Indeed, when the client starts, it has to authenticate with the server using public keys. Our protocol is based on the following schema:



As we can see from the schema, the protocol is a simplified version of SSL with client authentication. The only main difference is that the server does not need a certification authority to authenticate a client, but it has a list of registered users with their public key pre installed on it.

Like SSL, client and server share a pre master secret using asymmetric (RSA) encryption. Both symmetric key and IV are derived using OpenSSL *hkdf* library, which computes a key from a secret and a salt (nonce) using many iterations of hashing.

There are four main phases:

1. **Nonce exchange phase**: Both parts send to the other a random nonce. As it will be proven in 3, it is necessary to ensure the freshness of the communication and so avoiding replay attacks.

2. **Certificate exchange phase**: Client sends its username and then its public key to the server. Just one of these two information would be enough, but they are both sent to provide a further check on server side. Server then sends back its certificate, signed by a trusted certification authority. It's assumed that the client has the public key of this authority pre installed in a truststore. It's very important that at this point neither client or server have proven their identity. That is, they need to prove themselves owners of the public keys they are declaring.

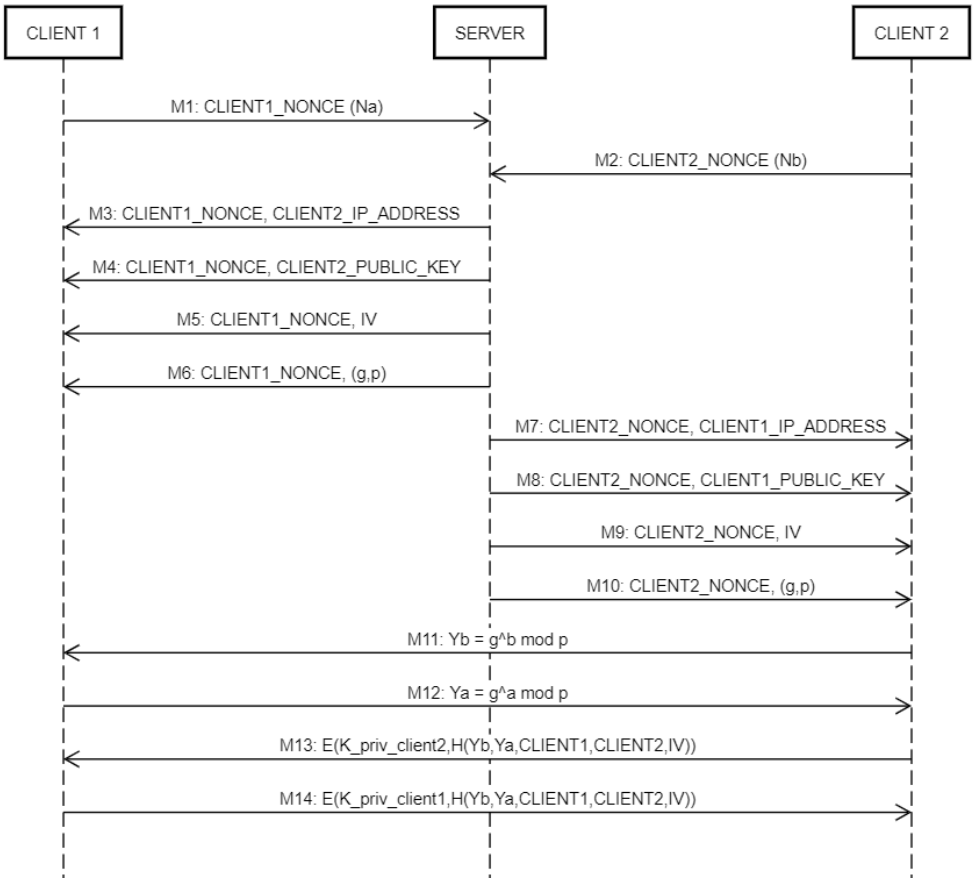
3. **Pre master secret**: The client computes a random pre master secret on 48 bits and sends it to the server. To ensure confidentiality it encrypts it in a digital envelope using server's public key. The authenticity of this message is proven in next phase.

4. **Authentication**: This part is crucial. Both client and server compute a digest of all previous messages (Pre master secret is added directly to the digest not encrypted) and the IV. This last digest component is not strictly required, but it gives an additional confidence that at the end of the authentication both parties have the same symmetric key. First client encrypts this digest using its private key and sends it to the server, which verifies it decrypting with client's public key and matching against the digest it had autonomously computed. If they match, the server does the same thing, encrypting the digest with its private key so that the client can verify as well. This guarantees that both parties are really who they claim to be. Nonces are crucial because, being included in the final digest, they ensure its freshness. Usernames and certificates are also included in the digest to avoid any form of Man in the Middle attack to the protocol.

2.2 P2P Handshake Protocol

This protocol aims to establish a secure connection between two peers, where secure means both authentication and confidentiality. The server has to provide both clients with the tools to authenticate each other, and it will not

know the game key they will share. Note that this P2P symmetric key will be valid just for one game.



As we can see in this schema, the protocol is composed on two main phases:

1. **Preparation phase**: The two peers cannot communicate directly from the beginning, because they do not have any information about the other but the username. Since they both consider the server an authority on clients' public keys, it's a server task to forward opponent's public key to each user, so that they can authenticate each other during the real P2P phase. Messages M1-M2, M3-M7, M4-M8, M5-M9, M6-M10 can be sent simoultaneously since server is multi threaded and communicates with clients at the same time. At the beginning clients send a nonce to the server, which will be included in all next server

messages to ensure their freshness. The task to generate a random initialization vector is delegated to the server in this phase, so that Diffie Hellman will be used only to share the symmetric key. IV could also be sent in the clear, but this way possible intruders won't even know it if they attempt an attack.

2. **P2P phase**: Now the two clients can communicate directly. As we can see, they perform a simple, non authenticated Diffie Hellman Key Exchange, and then use RSA for the authentication. Indeed, M13 and M14 provide authentication and freshness like last two messages in FRAH protocol. To avoid Man in the Middle it has been necessary to add to the signature clients' usernames, so that no malicious registered user can perform this kind of attack.

3 Ban Logic

3.1 FRAH Protocol

A is the client, S the server, C is a CA, Kas=H(Na,Ns,Psec).
Assumptions:

$$A \mid\equiv C \Rightarrow \overset{Ks}{\longmapsto} S, A \mid\equiv \overset{Kc}{\longmapsto} C$$

$$S \mid\equiv \overset{Ka}{\longmapsto} A, A \mid\equiv \overset{Ka}{\longmapsto} A$$

$$S \mid\equiv \overset{Ks}{\longmapsto} S, C \mid\equiv \overset{Ks}{\longmapsto} S$$

$$A \mid\equiv \#(Na), A \mid\equiv \#(Psec), S \mid\equiv \#(Nb)$$

Objectives:

$$A \mid\equiv A \overset{Kas}{\longleftrightarrow} S, A \mid\equiv \#(A \overset{Kas}{\longleftrightarrow} S), A \mid\equiv S \mid\equiv A \overset{Kas}{\longleftrightarrow} S$$

$$S \mid\equiv A \overset{Kas}{\longleftrightarrow} S, S \mid\equiv \#(A \overset{Kas}{\longleftrightarrow} S), S \mid\equiv A \mid\equiv A \overset{Kas}{\longleftrightarrow} S$$

Idealized Protocol:

M1:

$$A \rightarrow S : Na$$

M2:

$$S \rightarrow A : Nb$$

M3:

$$A \rightarrow S : A$$

M4:

$$A \rightarrow S : \overset{Ka}{\longmapsto} A$$

M5:

$$S \rightarrow A : S, \overset{Ks}{\longmapsto} S, \{S, \overset{Ks}{\longmapsto} S\}_{Kc^{-1}}$$

M6:

$$A \rightarrow S : \{Psec\}_{Ks}$$

M7:

$$A \rightarrow S : \{H(Na, Nb, M3, M4, M5, Psec, IV)\}_{Ka^{-1}}$$

M8:

$$S \rightarrow A : \{H(Na, Nb, M3, M4, M5, Psec, IV)\}_{Ks^{-1}}$$

Proof: After M5:

$$\frac{A \mid\equiv \overset{Kc}{\longmapsto} C, A \lhd \{\overset{Ks}{\longmapsto} S\}_{Kc^{-1}}}{A \mid\equiv C \mid\sim \overset{Ks}{\longmapsto} S}$$

A checks certificate expiration date and CRL, so it's sure that the certificate is fresh:

$$A \mid\equiv \#(\overset{Ks}{\longmapsto} S)$$

Using nonce verification rule:

$$\frac{A \mid\equiv \#(\overset{Ks}{\longmapsto} S), A \mid\equiv C \mid\sim \overset{Ks}{\longmapsto} S}{A \mid\equiv C \mid\equiv \overset{Ks}{\longmapsto} S}$$

So we can say that:

$$\frac{A \mid\equiv C \Rightarrow \overset{Ks}{\longmapsto} S, A \mid\equiv C \mid\equiv \overset{Ks}{\longmapsto} S}{A \mid\equiv \overset{Ks}{\longmapsto} S}$$

After M6:

$$\frac{S \mid\equiv \overset{Ks}{\longmapsto} S, S \lhd \{Psec\}_{Ks}}{S \lhd Psec}$$

At this point, both A and S can compute Kas and IV from Psec,Na,Nb hence:

$$A \mid\equiv A \overset{Kas}{\longleftrightarrow} S, S \mid\equiv A \overset{Kas}{\longleftrightarrow} S$$

And they also know that the key is fresh because:

$$A \mid\equiv \#(Na), A \mid\equiv \#(Psec)$$

$$A \mid\equiv \#(Psec, Na, Nb)$$

$$A \mid\equiv \#(A \overset{Kas}{\longleftrightarrow} S)$$

$$S \mid\equiv \#(Nb)$$

$$S \mid\equiv \#(Psec, Na, Nb)$$

$$A \mid\equiv \#(A \overset{Kas}{\longleftrightarrow} S)$$

But at this moment neither A nor S know for sure if they really are who they claim to be! To ensure that, we have M7 and M8.
After M7:

$$\frac{S \lhd \{H(Na, Nb, M3, M4, M5, Psec, IV)\}_{Ka^{-1}}, S \mid\equiv \overset{Ka}{\longmapsto} A}{S \mid\equiv A \mid\sim H(Na, Nb, M3, M4, M5, Psec, IV)}$$

$$\frac{S \mid\equiv A \mid\sim H(Na, Nb, M3, M4, M5, Psec, IV), S \triangleleft (Na, Nb, M3, M4, M5, Psec, IV)}{S \mid\equiv A \mid\sim (Na, Nb, M3, M4, M5, Psec, IV)}$$

Moreover:

$$\frac{S \mid\equiv \#(Nb), S \mid\equiv \#(IV)}{S \mid\equiv \#(Na, Nb, M3, M4, M5, Psec, IV)}$$

So we can say that:

$$\frac{S \mid\equiv A \mid\sim (Na, Nb, M3, M4, M5, Psec, IV), S \mid\equiv \#(Na, Nb, M3, M4, M5, Psec, IV)}{S \mid\equiv A \mid\equiv (Na, Nb, M3, M4, M5, Psec, IV)}$$

This ensures that

$$S \mid\equiv A \mid\equiv (Na, Nb, Psec)$$

and from this it's obvious that

$$S \mid\equiv A \mid\equiv A \overset{Kas}{\longleftrightarrow} S$$

After M8: we can apply the same procedure and verify that

$$A \mid\equiv S \mid\equiv A \overset{Kas}{\longleftrightarrow} S$$

The only difference is that freshness is given by

$$\frac{A \mid\equiv \#(Na), A \mid\equiv \#(Psec)}{A \mid\equiv \#(Na, Nb, M3, M4, M5, Psec, IV)}$$

These last 2 messages prove that:

- S and A are who they claim to be (authentication).
- No one changed the content of any message.
- All the handshake is fresh: no replay attacks are possible!

3.2 P2P Handshake Protocol

A,B are the clients, S the server, (g,p) the DH parameters.
Assumptions:

$$A \mid\equiv S \ \Rightarrow \overset{Kb}{\longmapsto} B \ , B \mid\equiv S \ \Rightarrow \overset{Ka}{\longmapsto} A$$

$$A \mid\equiv S \ \Rightarrow \ \#(\overset{Kb}{\longmapsto} B), B \mid\equiv S \ \Rightarrow \ \#(\overset{Ka}{\longmapsto} A)$$

$$A \mid\equiv S \ \Rightarrow \ \#(IVab), B \mid\equiv S \ \Rightarrow \ \#(IVab)$$

$$A \mid\equiv S \ \Rightarrow \ IVab, B \mid\equiv S \ \Rightarrow \ IVab$$

$$A \mid\equiv S \ \Rightarrow \ (g,p), B \mid\equiv S \ \Rightarrow \ (g,p)$$

$$Kab = g^{ab} modp$$

$$B \mid\equiv \ B \overset{Kbs}{\longleftrightarrow} S, B \mid\equiv \ \#(B \overset{Kbs}{\longleftrightarrow} S)$$

$$A \mid\equiv \ A \overset{Kas}{\longleftrightarrow} S, A \mid\equiv \ \#(A \overset{Kas}{\longleftrightarrow} S)$$

$$A \mid\equiv \ \#(Ya) \, B \mid\equiv \ \#(Yb) \ , A \mid\equiv \ \#(Nas) \ , B \mid\equiv \ \#(Nbs)$$

Objectives:

$$A \mid\equiv \ A \overset{Kab}{\longleftrightarrow} B, A \mid\equiv \ \#(A \overset{Kab}{\longleftrightarrow} B) \ , A \mid\equiv \ B \mid\equiv \ A \overset{Kab}{\longleftrightarrow} B$$

$$B \mid\equiv \ A \overset{Kab}{\longleftrightarrow} B, B \mid\equiv \ \#(A \overset{Kab}{\longleftrightarrow} B) \ , B \mid\equiv \ A \mid\equiv \ A \overset{Kab}{\longleftrightarrow} B$$

Idealized protocol:
Pre-phase:

M1:

$$A \rightarrow S : \{Nas\}_{Kas}$$

$$B \rightarrow S : \{Nbs\}_{Kbs}$$

M2:

$$S \rightarrow A : \{Nas, \overset{Kb}{\longmapsto} B \ , \#(\ \overset{Kb}{\longmapsto} B \ ) \ \}_{Kas}$$

$$S \rightarrow B : \{Nbs, \overset{Ka}{\longmapsto} A \ , \#(\ \overset{Ka}{\longmapsto} A \ ) \ \}_{Kbs}$$

M3:

$$S \rightarrow A : \{Nas, IVab, \#(IVab) \ \}_{Kas}$$

$$S \rightarrow B : \{Nbs, IVab, \#(IVab)\ \}_{Kbs}$$

M4:

$$S \rightarrow A : \{Nas, g, p\}_{Kas}$$
$$S \rightarrow B : \{Nbs, g, p\}_{Kbs}$$

P2P-phase:

M5:

$$B \rightarrow A : Yb = g^b modp$$

M6:

$$A \rightarrow B : Ya = g^a modp$$

M7:

$$B \rightarrow A : \{H(Yb, Ya, B, A, IVab)\}_{Kb^{-1}}$$

M8:

$$A \rightarrow B : \{H(Yb, Ya, B, A, IVab)\}_{Ka^{-1}}$$

Proof:
In the pre-phase we know for assumption that both A,B believe in their symmetric key with the server. So, we skip for brevity the following postulate:

$$\frac{P \mid\equiv\ Q \overset{K}{\leftrightarrow} P \lhd \{X\}_K}{P \lhd X}$$

in all pre-phase. After M2: After receiving Nas (Nbs), S said that Kb is B's public key (Ka is A's public key).

$$\frac{A \mid\equiv S \mid\equiv \overset{Kb}{\longmapsto} B, A \mid\equiv S \Rightarrow \overset{Kb}{\longmapsto} B}{A \mid\equiv \overset{Kb}{\longmapsto} B}$$

$$\frac{A \mid\equiv S \mid\equiv \#(\overset{Kb}{\longmapsto} B), A \mid\equiv S \Rightarrow \#(\overset{Kb}{\longmapsto} B)}{A \mid\equiv \#(\overset{Kb}{\longmapsto} B)}$$

For the same jurisdiction rule, we have:

$$B \mid\equiv \overset{Ka}{\longmapsto} A, B \mid\equiv \#(\overset{Ka}{\longmapsto} A)$$

After M3: Again for nonce verification both:

$$A \mid\equiv S \mid\equiv IVab, A \mid\equiv S \mid\equiv \#(IVab)$$

$$B \mid\equiv S \mid\equiv IVab, B \mid\equiv S \mid\equiv \#(IVab)$$

And again, for jurisdiction rule:

$$A \mid\equiv IVab, A \mid\equiv \#(IVab)$$

$$B \mid\equiv IVab, B \mid\equiv \#(IVab)$$

After M4: For jurisdiction rule, we have:

$$A \mid\equiv g, b$$

$$B \mid\equiv g, b$$

After M5:

$$A \triangleleft Yb$$

(A doesn't know who sent Yb)

After M6:

$$B \triangleleft Ya$$

(B doesn't know who sent Ya)

How to authenticate? For DHKE at this point both A,B can compute the shared key:

$$A \mid\equiv A \overset{Kab}{\longleftrightarrow} B, B \mid\equiv A \overset{Kab}{\longleftrightarrow} B$$

and:

$$A \mid\equiv \#(Ya), A \mid\equiv \#(IVab)$$

$$A \mid\equiv \#(Ya, Yb, IVab)$$

$$A \mid\equiv \#(A \overset{Kab}{\longleftrightarrow} B)$$

$$B \mid\equiv \#(Yb), B \mid\equiv \#(IVab)$$

$$B \mid\equiv \#(Ya, Yb, IVab)$$

$$B \mid\equiv \#(A \overset{Kab}{\longleftrightarrow} B)$$

Authenticaton is in M7,M8.

After M7:

$$\frac{A \triangleleft \{H(Yb, Ya, B, A, IVab)\}_{Kb^{-1}}, A \mid\equiv \overset{Kb}{\longmapsto} B}{A \mid\equiv B \mid\sim H(Yb, Ya, B, A, IVab)}$$

$$\frac{A \mid\equiv B \mid\sim H(Yb, Ya, B, A, IVab), A \lhd (Yb, Ya, B, A, IVab)}{A \mid\equiv B \mid\sim (Yb, Ya, B, A, IVab)}$$

Moreover:

$$\frac{A \mid\equiv \#(Ya), A \mid\equiv \#(IVab)}{A \mid\equiv \#(Yb, Ya, B, A, IVab)}$$

Nonce verification:

$$\frac{A \mid\equiv \#(Yb, Ya, B, A, IVab), A \mid\equiv B \mid\sim (Ya, Yb, B, A, IVab)}{A \mid\equiv B \mid\equiv (Ya, Yb, B, A, IVab)}$$

For DHKE then we get that

$$A \mid\equiv B \mid\equiv A \overset{Kab}{\longleftrightarrow} B$$

After M8: with same symmetric steps, we can prove that

$$B \mid\equiv A \mid\equiv A \overset{Kab}{\longleftrightarrow} B$$

with the only difference that freshness is given by

$$\frac{B \mid\equiv \#(Yb), B \mid\equiv \#(IVab)}{B \mid\equiv \#(Yb, Ya, B, A, IVab)}$$

Observation: A,B are in the digest to avoid any form of MIM attack.